

Плейбук реагирования на инцидент: Целенаправленная фишинг атака с компрометацией контроллера домена и кражей данных

1. Обнаружение и первичная классификация

Сигналы к реагированию:

- Сообщение сотрудника о необычном поведении компьютера (медленная работа, всплывающие окна, командная строка открывается и закрывается)
- Алерт EDR/AV о подозрительных процессах, запущенных из папки Downloads (например, Financial_Report_Q1_2025.exe)
- Алерт о исходящем соединении на внешний IP, не связанный с бизнес деятельностью (например, 138.124.182.161, 45.144.30.77, 194.87.252.221)
- Обнаружение модификации реестра в ключах автозагрузки (Run, RunOnce) нестандартными командами
- Множественные успешные или неудачные RDP-подключения с рабочих станций на серверы в нерабочее время

Действия (0–10 минут):

1. Проверить детали алерта в SIEM: изучить событие, определить затронутый хост и учётную запись
2. Проверить, не связано ли событие с плановыми работами или известной легитимной активностью
3. Проверить контекст: время входа, местоположение (если применимо), историю получения писем пользователем за последние 24 часа
4. Связаться с пользователем по ранее согласованному защищённому каналу либо по телефону, мессенджеру и подтвердить, открывал ли он подозрительное вложение или запускал незнакомый файл
5. При любых сомнениях назначить дополнительную проверку логов. Если инцидент подтверждается необходимо эскалировать на аналитиков второй линии (L2)

2. Сдерживание (10–30 минут)

Немедленные действия:

1. Изолировать скомпрометированные хосты от сети, оставив возможность сбора данных
2. Заблокировать на сетевом оборудовании IP-адреса C2 серверов и домены
3. Сменить пароли всех учётных записей, которые могли быть скомпрометированы
4. Ограничить RDP доступ к серверам только через VPN или с использованием многофакторной аутентификации

Проверки (30–60 минут):

1. Проверить наличие аналогичных признаков на других хостах в сети (поиск по IoC: хэши файлов, имена процессов, пути реестра)
2. Проверить, не были ли созданы новые учётные записи или изменены привилегии существующих (события 4720, 4732, 4733)
3. Проверить наличие дополнительных вредоносных файлов в системных папках и временных каталогах

3. Расследование

Сбор доказательств (1–2 часа):

1. Собрать полные логи Windows (Security, System, Application, PowerShell, Sysmon) со всех затронутых хостов
2. Сохранить копии вредоносных файлов (названия, пути, хэши) для дальнейшего анализа
3. Экспортировать записи реестра, относящиеся к закреплению (Автозагрузка)
4. Собрать сетевые логи с пограничного маршрутизатора или фаервола для подтверждения эксfiltrации данных
5. При необходимости собрать дампы памяти и образы дисков

Анализ (2–4 часа):

1. Построить хронологию атаки на основе временных меток
2. Классифицировать использованные техники MITRE ATT&CK
3. Определить точный объём утекших данных и чувствительность скомпрометированных файлов
4. Идентифицировать все учётные записи, к которым злоумышленник мог получить доступ
5. Проверить смежные системы на наличие следов компрометации

4. Искоренение угрозы

Действия (4–8 часов):

1. Удалить все обнаруженные вредоносные файлы на всех хостах
2. Удалить записи в реестре, обеспечивающие автозагрузку
3. Очистить любые запланированные задачи, которые могли быть созданы в момент атаки
4. При необходимости провести полную переустановку ОС на всех скомпрометированных хостах или восстановить систему из резервного

5. Восстановление

Действия (8–24 часа):

1. Восстановить данные с проверенных резервных копий, убедившись, что они не заражены

2. Настроить системы мониторинга (SIEM/EDR) с усиленными правилами для обнаружения подобных атак
3. Изменить пароли всех административных учётных записей и внедрить многофакторную аутентификацию (MFA)
4. После восстановления провести повторное сканирование сети на наличие IoC, чтобы убедиться в отсутствии скрытых бэкдоров
5. Провести учения для персонала по распознаванию фишинговых писем и корректному реагированию

6. Извлечённые уроки

Действия (после инцидента, 1–2 недели):

1. Провести внутреннее совещание с командой ИБ для разбора инцидента и поиска улучшений
2. Обновить политики безопасности: ужесточить фильтрацию вложений в почте, запретить исполняемые файлы в почтовом трафике
3. Внедрить регулярный аудит прав доступа к файловым ресурсам и сетевым папкам
4. Разработать и внедрить сценарии реагирования на подобные инциденты (на основе плейбуков, соответствующих лучшим практикам)
5. Оценить возможность использования угроз разведки (Threat Intelligence) для предупреждающей блокировки новых C2-серверов

7. Коммуникации

Внутренние:

1. Уведомить руководителя ИБ и юридический отдел о факте утечки данных
2. Подготовить внутреннее уведомление для сотрудников (без деталей угроз) с напоминанием о правилах обращения с вложениями и важности сообщения о подозрительных активностях
3. Уведомить всех владельцев затронутых систем о сроках изоляции и восстановления
4. Создать отчёт для аудиторов и регуляторов, если это требуется политикой компании

Внешние (при необходимости):

1. Связаться с командой разработчиков и/или поставщиками ПО (если уязвимости связаны с конкретными продуктами)
2. Уведомить регулятора (например, Роскомнадзор) в случае утечки персональных данных
3. [Опишите третью внешнюю коммуникацию]
4. При необходимости привлечь внешнюю компанию для форензики и сертификации восстановления

8. Критерии эскалации

Эскалировать инцидент, если:

- Затронут контроллер домена или другой критический сервер
- Выявлена утечка персональных данных или коммерческой тайны
- Вредоносное ПО сохраняет способность к самовосстановлению или повторному заражению после удаления
- Есть вероятность, что атака продолжается и распространяется на другие сегменты сети
- Требуется участие руководства для принятия оперативных решений (изоляция бизнес-критичных систем, привлечение правоохранительных органов)

Приложение С: Шаблоны уведомлений (Напишите тексты писем и кому и куда бы вы написали в случае инцидента)

Шаблон внутреннего уведомления

Тема: Срочно: [Тип инцидента, например: Фишинг-атака / Компрометация учётной записи / Вредоносное ПО] [Краткая суть, например: обнаружена подозрительная активность]

Уважаемые коллеги,

[Дата и время обнаружения, например: 15 апреля 2025 года] зафиксирована [кратко: атака / инцидент / подозрительная активность], которая затронула [перечислить затронутые системы или подразделения]

В настоящее время команда информационной безопасности проводит [мероприятия: расследование / изоляцию / восстановление]. Мы рекомендуем:

- Не открывать подозрительные вложения и не переходить по ссылкам из неизвестных писем.
- Немедленно сообщать о любых необычных явлениях на вашем компьютере (замедление работы, всплывающие окна, запросы на ввод пароля) в ИБ-отдел по [указать каналы связи: телефон, почта, чат].
- В случае, если вы открыли вложение или выполнили подозрительную команду - незамедлительно свяжитесь с ИБ и не выключайте компьютер.

О дальнейших шагах мы сообщим дополнительно. Приносим извинения за возможные неудобства.

Контактные данные ИБ-отдела: [телефон, email, внутренний чат]

С уважением,
Команда информационной безопасности

Шаблон внешнего уведомления (если применимо)

Тема: Кибернападение/Другая тема – [обновление статуса расследования]

Уважаемое руководство,

[Дата] мы зафиксировали [тип атаки/другое действие], направленную на [цели / системы]. По предварительным данным, [краткое описание воздействия: скомпрометированы учётные записи, возможна утечка данных, нарушена работа сервисов].

Текущий статус:

Затронуты системы: [перечислить]

Предварительные выводы: [краткая версия для руководства]

Принятые меры: [изоляция, смена паролей, привлечение экспертов]

Ближайшие шаги: [продолжение анализа, восстановление, уведомление регуляторов]

Дополнительную информацию предоставим по итогам расследования. Если требуется оперативное решение по [вопрос], просим связаться с [ответственное лицо].

[Должность, контакт]

С уважением,
[Название организации]